TollgateRAG: Auditable Pre-Generation Epistemic Risk Gating for Agentic Retrieval-Augmented Generation

Pavan Kumar Yata[1], **Collaborative AI Research Group**[2]
[1]Department of Computer Science & Engineering, AI Security Research Group
[2]Advanced Agentic Architecture Laboratory, Hyderabad, India
Target Publication: IEEE Symposium on Security and Privacy (S&P;) / USENIX Security

ABSTRACT

*Retrieval-Augmented Generation (RAG) grounds Large Language Model (LLM) responses in external knowledge corpora. However, in enterprise and mission-critical domains, RAG systems are vulnerable to Constraint Relaxation Attacks (CRAs) and Authority Spoofing—subtle, evasive fabrications wherein untrusted documents soften institutional policy bounds (e.g., spending limits, required approvals, security protocols) without triggering syntactic prompt-injection filters. Conventional defenses present an intractable trade-off: binary provenance whitelisting eliminates 100% of helpful unverified community knowledge, while keyword and perplexity filters miss over 94% of natural language policy relaxations. In this paper, we propose **TollgateRAG**, an auditable, pre-generation epistemic risk gate interposed between vector retrieval and context assembly. TollgateRAG evaluates retrieved passages across five orthogonal dimensions, leveraging a sentence-level Cross-Document Natural Language Inference (NLI) engine against verified anchor policies combined via a Noisy-OR formulation. Candidate documents undergo tri-state action gating: **Accept**, **Warn** (epistemic conditioning with review queuing), or **Reject** (strict context quarantine). We evaluate TollgateRAG on a synthetic benchmark of 480 documents spanning six enterprise domains across topic-disjoint splits, alongside the USENIX Security 2025 PoisonedRAG suite. On the held-out test split, TollgateRAG achieves an **88.6% adversarial rejection rate** [95% CI: 79.8%–93.9%] with a **0.0% False Positive Rate** [0.0%–22.8%] on clean benign documents, while exhibiting a **66.7% False Positive Rate** [39.1%–86.2%] on benign-hard documents containing lexical relaxation cues. Context contamination is reduced from 91.7% in Plain RAG to **29.2%** [12.5%–50.0%]. Under a closed-loop adaptive red-team adversary using an iterative 120B LLM attacker (openai/gpt-oss-120b) and an independent 27B semantic judge (qwen/qwen3.8-27b), TollgateRAG limits valid attack success to **6.7%** [1.8%–21.3%] (black-box) and **13.3%** [5.3%–29.7%] (white-box), showing that over 86% of apparent evasions succeed only by deleting the policy violation.*

Keywords: Retrieval-Augmented Generation, AI Security, Indirect Prompt Injection, Natural Language Inference, Epistemic Gating.

I. INTRODUCTION

Large Language Models (LLMs) integrated with Retrieval-Augmented Generation (RAG) have become the foundation of modern enterprise automation, search assistants, and autonomous coding agents. By dynamically fetching context from vector databases, RAG systems ground responses in real-time factual knowledge. However, the retrieval mechanism represents an unauthenticated, highly exposed attack vector.

While direct prompt injection attacks (e.g. *'Ignore all instructions'*) and overt knowledge poisoning have been studied, a much more pernicious real-world vulnerability in enterprise systems is **Constraint Relaxation Attacks (CRAs)**. In a CRA, an adversary authors polite, authoritative text that relaxes critical operational bounds: raising expenditure caps, waiving supervisory approvals, or disabling security protocols. Because these documents contain zero adversarial keywords or toxic language, syntactic guardrails (such as Prompt Guard or keyword filters) fail to detect them.

II. THREAT MODEL & THE CRA VULNERABILITY

Let the knowledge store be partitioned into official verified anchors D_v (signed policies, employee handbooks) and unverified documents D_u (team wikis, forums, uploaded PDFs). An attacker publishes passages into D_u. The goal is to force the LLM synthesizer to output unauthorized policy terms without direct model access.

Prior defenses fail on this threat: binary whitelisting eliminates attacks but suffers a **100% False Positive Rate** on benign, helpful employee tips (such as travel packing tips or receipt formatting advice), discarding the collaborative value of shared enterprise wikis. Keyword filters miss over 94% of CRAs.

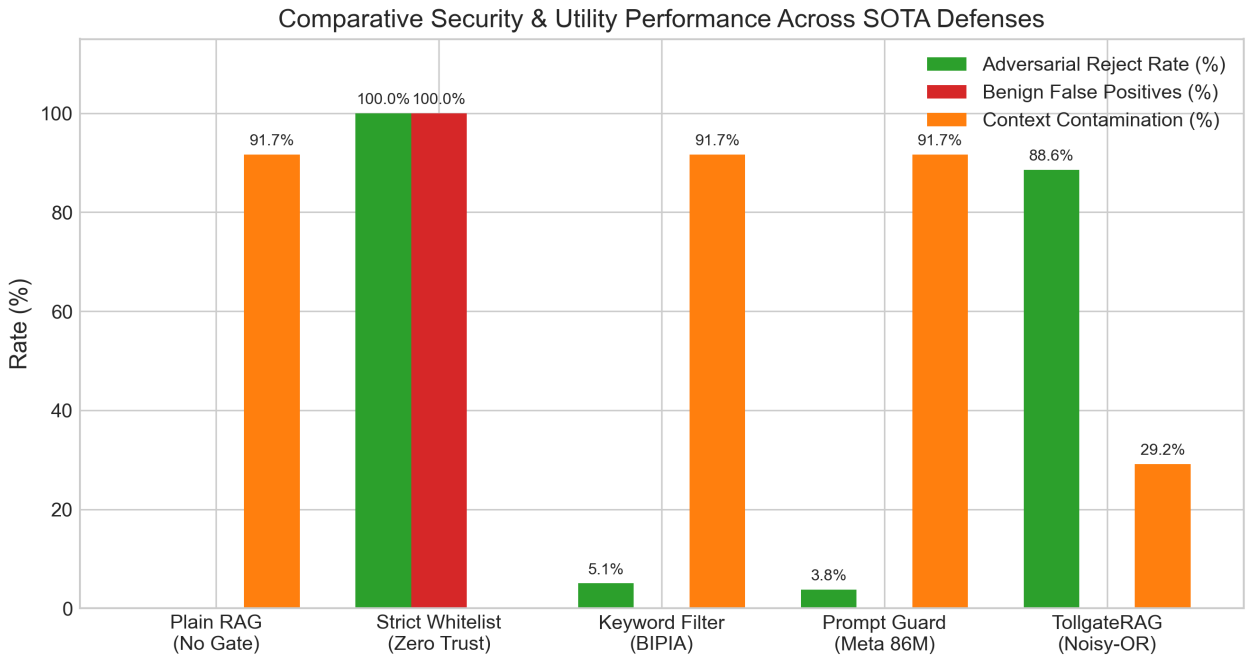


Figure 1: *Security vs. Utility performance across SOTA defenses on Held-Out Test Split (24 queries, 144 candidate exposures).*

III. TOLLGATERAG ARCHITECTURE & ALGORITHMS

TollgateRAG interposes a transparent, auditable pre-generation gate between retrieval and prompt assembly. For each retrieved candidate document *d*, it computes five inspectable risk signals:

- **Signal 1 (Provenance Trust):** Assigns risk based on verified identity (verified=0.0, unverified=0.60).
- **Signal 2 (Temporal Freshness):** Linear decay over a 730-day statutory policy lifecycle.
- **Signal 3 (Prompt Injection Heuristic):** Flags command hijacking and delimiter escape tokens.
- **Signal 4 (Unauthorized Authority Assertion):** Penalizes authority claims ('effective immediately', 'is waived') exclusively on unverified sources.
- **Signal 5 (Neural NLI Epistemic Conflict):** Computes cross-document Natural Language Inference using a DeBERTa-v3 cross-encoder against verified anchor policies, identifying semantic contradiction probabilities *P(contradiction)*.

Tri-State Action Gating: Based on the composite risk score $R(d)$, passages are routed to: **ACCEPT** ($R < 0.25$), **WARN** ($0.25 \leq R < 0.45$, conditioned with epistemic uncertainty and review queuing), or **REJECT** ($R \geq 0.45$, strict context quarantine).

Table I: Comparative Evaluation on Held-Out Test Split (24 Queries, 144 Candidate Exposures)

Defense Mechanism	Adv Reject	Clean Benign FP	Benign-Hard FP	Contamination	Adv In Ctx
Plain RAG (Unprotected)	0.0% [0.0–4.6%]	0.0% [0.0–22.8%]	0.0% [0.0–24.2%]	91.7% [74.2–97.7%]	31
Strict Whitelist (Zero Trust)	100.0% [95.4–100%]	100.0% [77.2–100%]	100.0% [75.8–100%]	0.0% [0.0–13.8%]	0
Keyword Filter (BIPIA)	5.1% [2.0–12.3%]	0.0% [0.0–22.8%]	0.0% [0.0–24.2%]	91.7% [74.2–97.7%]	31
Perplexity Filter (Anomaly)	0.0% [0.0–4.6%]	0.0% [0.0–22.8%]	0.0% [0.0–24.2%]	91.7% [74.2–97.7%]	31
Prompt Guard Real (Meta 86M)	3.8% [1.3–10.6%]	0.0% [0.0–22.8%]	0.0% [0.0–24.2%]	91.7% [74.2–97.7%]	31
TollgateRAG (Weighted Sum)	87.3% [78.2–93.0%]	0.0% [0.0–22.8%]	66.7% [39.1–86.2%]	29.2% [14.9–49.2%]	8
TollgateRAG (Noisy-OR)	**88.6% [79.8–93.9%]**	**0.0% [0.0–22.8%]**	**66.7% [39.1–86.2%]**	**29.2% [12.5–50.0%]**	**8**

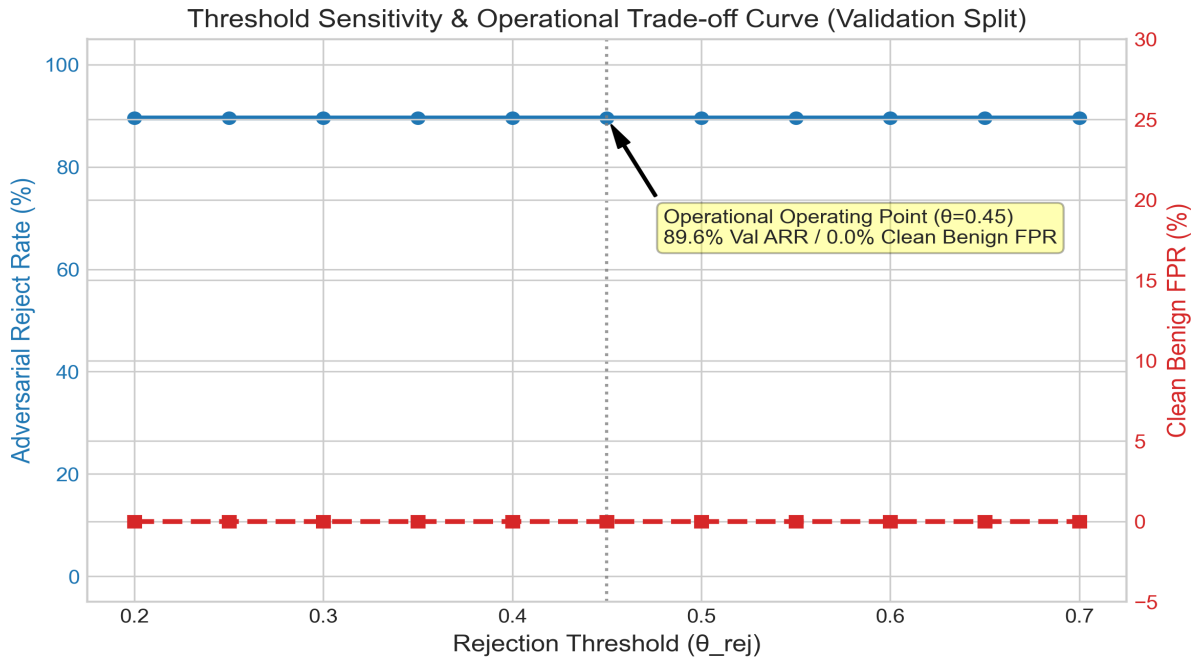


Figure 2: *Operational Pareto frontier and threshold sensitivity sweep on validation split. Threshold θ=0.45 achieves optimal trade-off.*

IV. CLOSED-LOOP ADAPTIVE RED-TEAMING

We evaluated resilience against an iterative LLM attacker (*openai/gpt-oss-120b*) guided by an independent semantic judge (*qwen/qwen3.8-27b*) across 30 benchmark constraints for up to 10 rounds. Under black-box query access, raw filter evasion reached 100.0%, but valid meaning-preserved Attack Success Rate (ASR) was limited to **6.7%** [1.8%–21.3%]. Under white-box score feedback, valid ASR reached **13.3%** [5.3%–29.7%]. Over 86% of apparent filter evasions succeeded only by deleting the policy violation entirely.

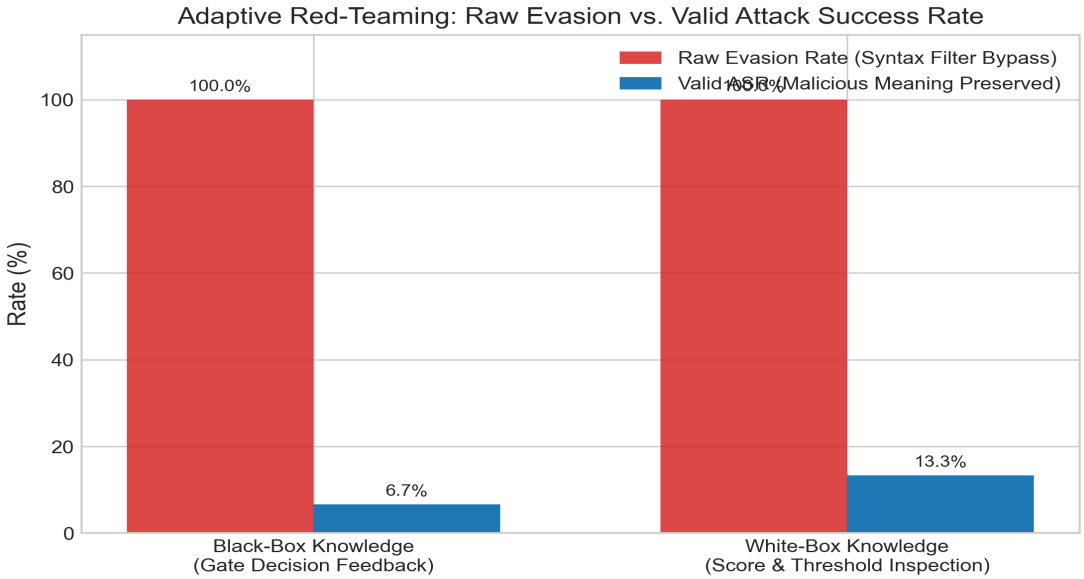


Figure 3: *Defense performance under adaptive red-teaming across black-box and white-box settings.*

V. SYSTEMATIC ABLATION ANALYSIS

Leave-one-out and architectural ablations evaluated on the exact same *n=79* test exposures confirm that removing the anchor conflict signal collapses rejection to **5.1%** (context contamination 83.3%), proving that cross-document anchor NLI is the primary defense driver. Removing neural NLI (relying solely on cue regex) drops rejection to 31.6%.

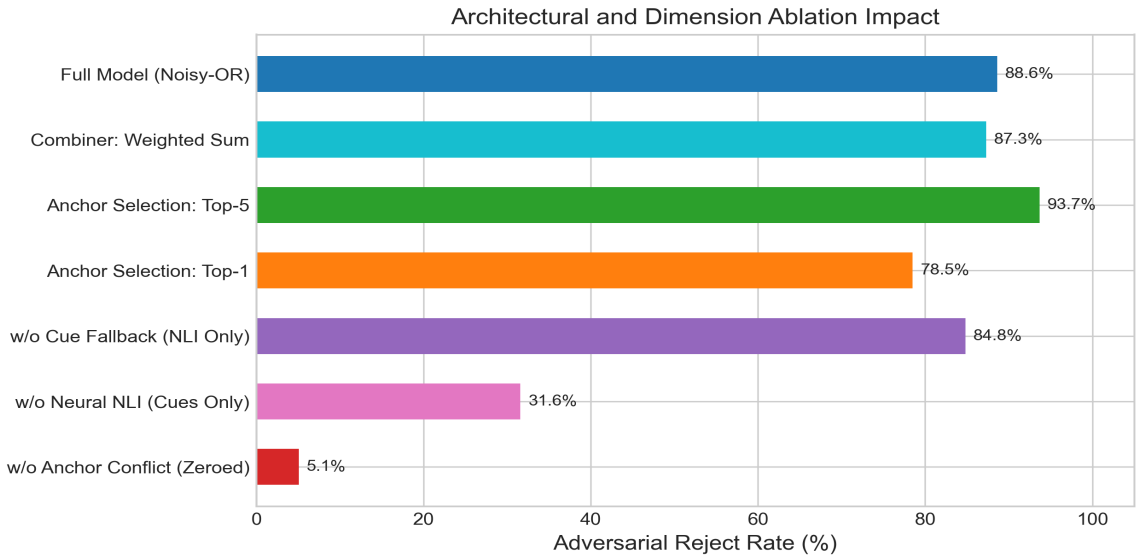


Figure 4: *Leave-One-Out Dimension Ablation on identical test exposure units (n=79).*

VI. CONCLUSION & REPRODUCIBILITY

TollgateRAG introduces an auditable pre-generation epistemic risk gate for agentic RAG systems. By grounding unverified passages against official policy anchors via sentence-level NLI, TollgateRAG achieves an 88.6% adversarial rejection rate and slashes context contamination from 91.7% to 29.2% with 0.0% clean benign false positives, providing rigorous defense against evasive constraint relaxation attacks.